SECURITY · INTERNAL

Security Remediation Register

Hardening items identified by the 26 September 2026 security assessment, with their fixes, owners' effort estimates and the tests that prove each one closed. Companion to the Security Architecture & Assurance Report.

CONFIDENTIAL: TECRES ENGINEERING AND LEADERSHIP ONLY

TecresTrackIT AMS
Version 1.0 · 26 September 2026

...go beyond paper
Tecres

LEADERSHIP, ENGINEERING

1 Register

Each item has an automated test in `src/test/security/pentest.security.test.ts` written as an expected failure (`it.fails`). When the fix lands, the test starts passing and the suite fails on purpose until the test is changed to a normal `it`, so closure is proven by the test run, not by assertion.

ID	ITEM	SEVERITY	TEST	STATUS
F-01	Password-only token accepted as a console session (two-factor bypass)	Critical	PT-06	Fixed, deploy
F-02	Leftover public endpoint lets anyone create an organization	High	PT-27	Open
F-03	Console authenticator codes can be replayed within their window	Medium	PT-17	Open
F-04	No lockout on console accounts after wrong passwords	Medium	PT-18	Open
F-05	Deactivated users keep access until their token expires (up to 15 min)	Medium	PT-25	Open
F-06	An org admin can demote or deactivate the last super admin	Medium	PT-26	Open
F-07	Dependencies with published advisories	Medium	audit	Open
F-08	Sign-in timing and workspace lookup reveal registered emails	Low	PT-14	Open
F-09	Password policy is length 8 only	Low	review	Open
F-10	Oversized requests answered 500 instead of 413	Low	PT-29	Open

ENGINEERING

2 Item details and fixes

F-01 · Two-factor bypass on the platform console Fixed

Pre-auth tokens shared a signing secret with session tokens and the session check verified only the signature. Fixed by giving every token type its own JWT audience (`src/lib/jwt.ts`). Before: platform read routes returned 200 to a pre-auth token. After: 401 everywhere. **Action:** deploy to production; platform admins sign in once more after deployment.

F-02 · Public organization creation

`POST /api/organizations` is unauthenticated. Beyond bypassing onboarding, because emails are unique platform-wide an attacker could pre-register a prospect's email and block their onboarding. **Fix:** delete the route (the frontend uses `POST /api/platform/orgs`) and move the integration tests to the platform route.

F-03 · Console authenticator code replay

Customer sign-in stores the last accepted time-step; the console passes `null`. **Fix:** add `totp_last_used_step` to `platform_admins` and pass it through, mirroring the customer implementation.

```
const result = verifyTotpCode(secret, code, admin.totpLastUsedStep);
if (result.valid) await db.update(platformAdmins).set({ totpLastUsedStep: result.step
}).where(eq(platformAdmins.id, admin.id));
```

F-04 · Console account lockout

Only the per-IP rate limit applies, which distributed guessing avoids, and failed console sign-ins are not logged. **Fix:** add `failed_login_attempts` / `locked_until` to `platform_admins`, reuse the customer lockout (5 attempts, 15 minutes) and log failures to the platform admin log.

F-05 · Access after deactivation

Access tokens are verified by signature only, so deactivation or a role change takes effect when the token expires. **Fix:** in `loadOrgContext` also load the user, reject inactive users and use the stored role; revoke refresh tokens on deactivation; add the same check to `authenticatePlatformAdmin`.

F-06 · Last super admin can be removed

`PUT` / `DELETE /api/people/:id` let any admin change any role, including all super admins and themselves. **Fix:** only a super admin may grant or remove `super_admin`; refuse any change leaving zero active super admins; forbid self-demotion and self-deactivation.

F-07 · Dependencies

PACKAGE	ADVISORIES	REACHABLE HERE?	ACTION
`nodemailer` 6.9	12 (3 high): address-parser DoS, header injection, recipient-domain bypass	Partly: recipients come from user-entered emails	Upgrade to 9.1.1+
`drizzle-orm` 0.36	1 high: identifier escaping	No: user sort choices map to a fixed list	Upgrade to 0.45.2+
`qs`	2 moderate	Possibly, via query strings	Upgrade to 6.16+
`xlsx` (frontend)	1 high, parsing only	No: the app only writes files	Replace with maintained build or `exceljs`

F-08 · Account discovery

Sign-in takes about 137 ms for a real account and 6 ms for an unknown email; the sign-in page's workspace lookup also confirms whether an email is registered (rate-limited). **Fix:** verify against a dummy argon2 hash when no user exists; optionally return default Tecres branding instead of 404 from the lookup.

F-09 · Password policy

Fix: minimum 12 characters and a breached-password check (Have I Been Pwned range API), per NIST SP 800-63B. Mandatory two-factor limits current exposure.

F-10 · Oversized request handling

The body-size limit works, but the error handler reports it as a 500 and logs it as a crash. **Fix:** in `errorHandler.ts`, pass through errors with a 4xx `status` (for example 413 `entity.too.large`).

LEADERSHIP, ENGINEERING

3 Plan

WHEN	WORK	ITEMS	EFFORT
Immediately	Deploy the token-audience fix	F-01	1 hour
This sprint	Remove public org creation; console replay protection and lockout; status check on every request; super-admin guards	F-02 to F-06	2 days
Next sprint	Dependency upgrades and full re-test	F-07	1 day
Backlog	Constant-time sign-in, password policy, 413 handling	F-08 to F-10	0.5 day
Before scaling out	Redis-backed rate limits and a single job scheduler; production configuration review (TLS, proxy, SPA headers, database exposure, backups)	n/a	1 to 2 days

When an item closes, update its row here and add its test to the relevant table of the Security Architecture & Assurance Report.